Cybersecurity Basics & Core Concepts

Fundamental Principles, Threat Mechanisms, and Attack Vectors

Executive Overview: Cybersecurity is the discipline of protecting computer systems, networks, devices, and data from digital attacks, unauthorized access, and malicious damage. Effective security postures require balancing technical safeguards, organizational policies, and human awareness to maintain operational resilience across expanding digital attack surfaces.

1. The CIA Triad: Foundational Pillars

The **CIA Triad** is the industry-standard framework used to guide information security policies, evaluate risk models, and architect defensive controls. Every security control or breach addresses at least one pillar of this triad.

A. Confidentiality

Concept: Confidentiality ensures that sensitive data is accessible strictly to authorized users, applications, and processes, preventing unauthorized exposure or disclosure.

- **Encryption Mechanisms:** Protects data at rest (AES-256) and data in transit (TLS 1.3) so that intercepted data remains unreadable.
- **Access Control Architecture:** Implements Role-Based Access Control (RBAC) and the Principle of Least Privilege, granting users only the minimum access necessary.
- **Identity Authentication:** Enforces Multi-Factor Authentication (MFA) to prevent unauthorized account takeover.
- **Data Protection Controls:** Utilizes data masking, tokenization, and strict media disposal procedures.

B. Integrity

Concept: Integrity guarantees that information remains accurate, complete, and authentic, assuring that data has not been modified, corrupted, or deleted by unauthorized parties.

- **Cryptographic Hashing:** Uses mathematical algorithms (e.g., SHA-256) to produce unique checksums. Any alteration in input data radically alters the resulting hash value.
- **Digital Signatures:** Combines hashing with asymmetric cryptography to verify sender identity and ensure non-repudiation.
- **Audit Logs & System Integrity:** Implements write-once audit logging, file integrity monitoring (FIM), and database transaction controls.

C. Availability

Concept: Availability ensures that critical systems, networks, and applications are continuously accessible to authorized users whenever required.

- **Infrastructure Redundancy:** Deploys cluster configurations, dual power supplies, and geo-redundant cloud infrastructure.

- **Failover & Backups:** Maintains automated failover triggers and rigorous 3-2-1 backup strategies (3 copies, 2 media types, 1 offsite/air-gapped).
- **Traffic Management:** Utilizes Denial-of-Service scrubbing, load balancing, and bandwidth rate-limiting.

> **CIA Triad Balance Rule**
>
> A robust security posture maintains an equilibrium across all three pillars. Over-emphasizing Confidentiality (e.g., extreme encryption or restrictive permissions) can degrade Availability, while prioritizing unrestricted Availability can compromise Confidentiality and Integrity.

2. Primary Threat Types & Mechanisms

Cyber threats encompass deliberate actions executed by malicious actors to exploit vulnerabilities, disrupt business continuity, steal intellectual property, or extort financial gain.

A. Phishing

Definition: A social-engineering-driven scam conducted via electronic communication (email, SMS, voice) designed to deceive recipients into revealing credentials, clicking malicious links, or transferring funds.
• *Spear Phishing:* Highly customized attacks targeted at specific individuals or roles.
• *Whaling:* Tailored phishing aimed specifically at executive leadership.
• *Key Defenses:* Email authentication protocols (SPF, DKIM, DMARC), anti-phishing gateways, and continuous user simulation training.

B. Malware (Malicious Software)

Definition: An umbrella term for intrusive code written to cause harm, compromise system security, or exfiltrate data.
• *Viruses & Worms:* Malicious code that attaches to files or autonomously spreads across network devices.
• *Trojans:* Disguised as legitimate software to establish hidden backdoors (e.g., Remote Access Trojans - RATs).
• *Spyware & Keyloggers:* Covertly records keystrokes, browser activity, and sensitive personal information.
• *Fileless Malware:* Executes in memory using native system utilities (e.g., PowerShell) without writing files to disk.
• *Key Defenses:* Endpoint Detection and Response (EDR), Next-Gen Antivirus (NGAV), application whitelisting.

C. Distributed Denial of Service (DDoS)

Definition: An attempt to render an online service unavailable by swamping the target server or network infrastructure with overwhelming volumes of flood traffic generated across a botnet (zombie network of compromised devices).
• *Volumetric Attacks:* Consumes network bandwidth (e.g., UDP/ICMP floods).
• *Protocol Attacks:* Targets server resources and network equipment (e.g., SYN floods).
• *Application Layer Attacks:* Targets web applications with high-resource HTTP requests.
• *Key Defenses:* Anycast network routing, Cloudflare/AWS Shield DDoS scrubbing, rate limiting.

D. SQL Injection (SQLi)

Definition: An attack technique where malicious SQL commands are inserted into unsecured web application input fields (e.g., login forms, search boxes), forcing the database engine to execute unintended commands.

• *Impact:* Bypassing authentication, extracting confidential database records, altering data, or executing administrative OS commands.

• *Key Defenses:* Parameterized queries (prepared statements), strict input validation/sanitization, Web Application Firewalls (WAF).

E. Brute Force Attacks

Definition: An automated trial-and-error approach where an attacker systematically tests every possible combination of passwords, passphrases, or encryption keys until the correct one is discovered.

• *Variants:* Dictionary Attacks (using wordlists), Credential Stuffing (testing stolen username/password pairs across multiple sites), Password Spraying (testing a common password against many accounts).

• *Key Defenses:* Account lockout thresholds, CAPTCHA verification, high-entropy password requirements, MFA.

F. Ransomware

Definition: A virulent form of malware that encrypts a victim's files or locks their operating system, demanding a cryptocurrency ransom in exchange for the decryption key.

• *Double Extortion:* Attackers steal sensitive data before encrypting it, threatening public leak if ransom is unpaid.

• *Key Defenses:* Offline air-gapped backups, zero-trust segmentation, rapid isolation procedures, disabling legacy protocols (e.g., SMBv1).

---

3. Attack Vectors & Entry Pathways

An **attack vector** represents the specific path, method, or entry point threat actors exploit to infiltrate a target network, deliver a malicious payload, or exfiltrate sensitive assets.

A. Social Engineering (The Human Vector)

Overview: Exploits psychological manipulation—targeting human cognitive biases such as trust, fear, urgency, or helpfulness—to induce individuals into breaking security procedures.

• *Pretexting:* Creating a fabricated scenario or identity to trick victims into surrendering data.

• *Baiting:* Leaving malware-infected physical devices (e.g., USB drives) in public spaces.

• *Piggybacking / Tailgating:* Following an authorized person through secured physical doors.

• *Countermeasures:* Security awareness culture, mandatory verification rules, clear escalation policies.

B. Wireless Network Attacks

Overview: Targets radio frequency communications and wireless access protocols to intercept unencrypted traffic, spoof network identities, or inject rogue hardware.

• *Rogue Access Points:* Unauthorized wireless routers connected to an internal network.

• *Evil Twin Attacks:* Fraudulent access points broadcasting the same SSID as a legitimate network to intercept user credentials.

• *Eavesdropping / MitM:* Intercepting wireless frames over open or weakly encrypted networks.

• *Countermeasures:* WPA3-Enterprise, Wireless Intrusion Prevention Systems (WIPS), mandatory corporate VPNs.

C. Insider Threats

Overview: Security risks originating from current or former employees, contractors, or trusted partners who possess legitimate access privileges to internal systems.
• *Intentional / Malicious Insiders:* Driven by greed, revenge, or espionage to steal data or sabotage systems.
• *Unintentional / Negligent Insiders:* Well-meaning staff who make security errors, misconfigure cloud storage, or fall for phishing.
• *Compromised Insiders:* Legitimate user credentials hijacked by external adversaries.
• *Countermeasures:* User and Entity Behavior Analytics (UEBA), strict Data Loss Prevention (DLP), Principle of Least Privilege, prompt offboarding privilege revocation.

4. Defense-in-Depth Reference Matrix

The following matrix summarizes the correlation between threat types, attack vectors, impacted CIA triad pillars, and recommended primary defensive controls.

Threat / Vector	Targeted CIA Pillar	Primary Impact	Essential Defensive Controls
Phishing	Confidentiality & Integrity	Credential theft, initial entry	MFA, Email Gateway (SPF/DKIM/DMARC), User Training
Malware	Integrity & Confidentiality	Data corruption, system takeover	EDR / NGAV, Application Whitelisting, Patching
DDoS	Availability	Service outage, downtime	CDN, Anycast Routing, DDoS Scrubbing Services
SQL Injection	Confidentiality & Integrity	Database breach, data deletion	Parameterized Queries, Input Validation, WAF
Brute Force	Confidentiality	Unauthorized account access	Lockout Policies, CAPTCHA, High Entropy Passwords, MFA
Ransomware	Availability & Confidentiality	Data encryption, double extortion	Air-Gapped Backups, Network Segmentation, EDR
Social Engineering	Confidentiality & Integrity	Bypassing security barriers	Awareness Simulation, Multi-channel Verification
Wireless Attacks	Confidentiality & Integrity	Traffic interception, Man-in-the-Middle	WPA3-Enterprise, WIPS, Enforced Corporate VPN
Insider Threats	All Three Pillars (CIA)	Sabotage, IP theft, leaks	UEBA, Least Privilege / RBAC, DLP, Offboarding Audit